

Target Name - Metasploitable 2 and Badstore**Title - Red Team Fundamentals****Date - 20/04/2026****Introduction**

The primary objective of these tasks was to simulate a complete attack-and-defense lifecycle in a controlled environment, moving from initial threat hunting and malware analysis to active exploitation and final risk mitigation. The scope of this project involved the integration of several industry-standard tools-including Metasploit, Wazuh, Suricata, and Velociraptor to bridge the gap between offensive operations and defensive engineering.

Table of Contents

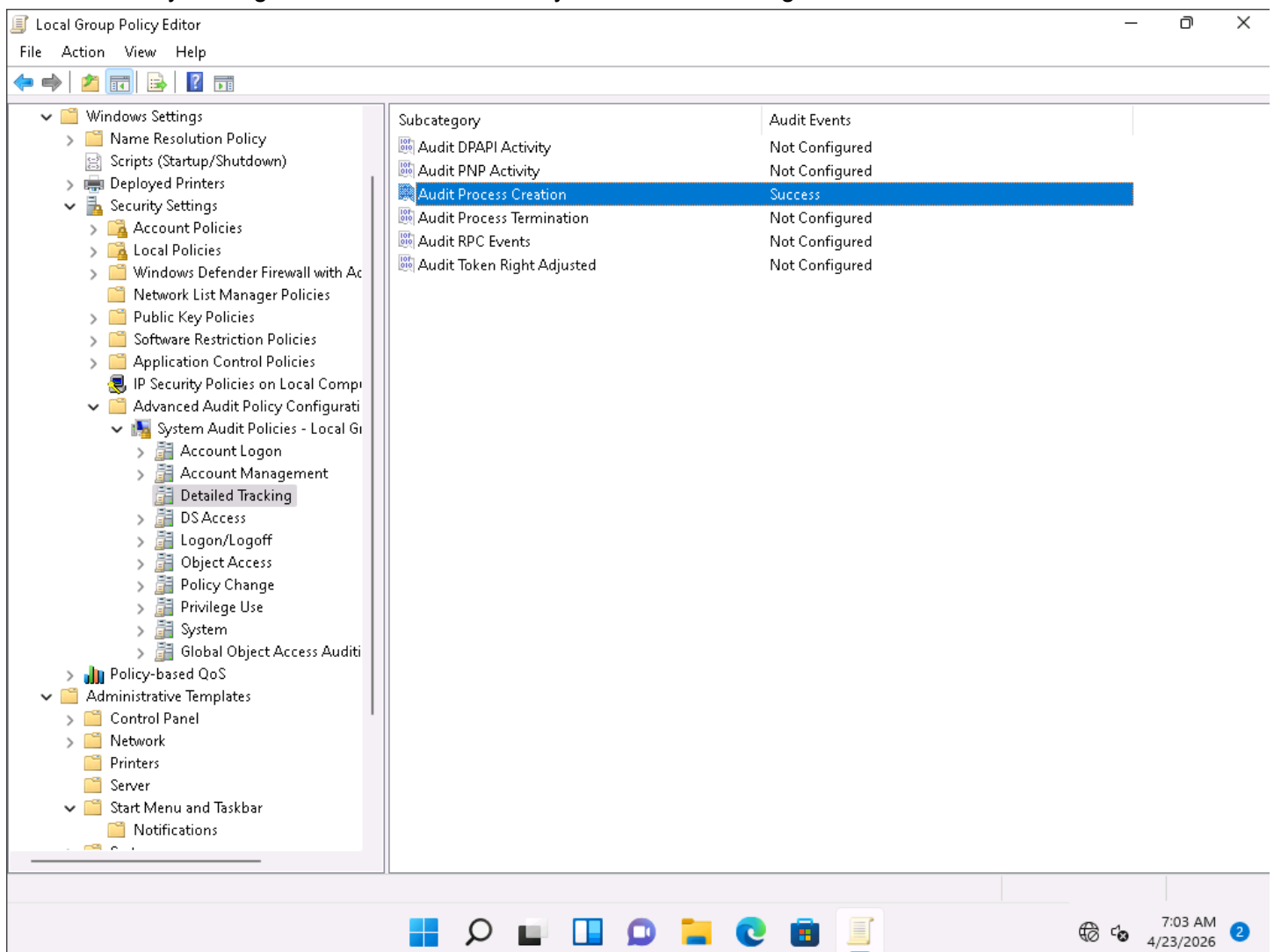
S.No	Name of the Topic	Page No.
1.	Threat Hunting • Sigma rule used in this	2 - 3
2.	Malware Analysis • Tools used • Analyzing File using REMnux tools ◦ Static Analysis using strings ◦ Dynamic Analysis using Hybrid-Analysis • Comparing Hybrid-Analysis and REMnux tools report	4 - 5
3.	Building a Vulnerability Management Pipeline • Tools Used • Steps to scan target in OpenVAS and importing report in DefectDojo • Prioritized Vulnerabilities and Mitigations • Mitigation Steps of each Vulnerability	
4.	Incident Response Simulation • Tools used • Configuring Velociraptor and Caldera	8 - 9
5.	Network Defense • Tools used • Configuring and Testing Suricata • Mapping Suricata alert to MITRE ATT&ACK	10
6.	Risk Assessment • Tools Used • Quantitative Risk Analysis • Ransomware Scenario	11 - 12
7.	Incident Response Cycle • Tools Used • The incident, including findings, actions, and recommendations	13

Threat Hunting

Threat Hunting is a proactive cybersecurity discipline where security professionals actively search through networks, endpoints, and systems to detect and isolate advanced threats that have evaded automated security solutions. Tools used in this section are Elastic Security, Security Onions and Sigma rules. Security Onion is a linux based platform for threat hunting and log management that integrates Elastic Security for analytics and utilizes Sigma rules to detect suspicious behaviour across logs.

Before writing rules, the data must be structured correctly, For windows environments Elastic Agent is used to ship logs to the Elastic Stack.

1. Enable Audit Process Creation: Open “gpedit.msc” > Computer Configuration > Windows Settings > Security Settings > Advanced Audit Policy > Detailed Tracking > Audit Process Creation.



2. Same as above Go to Administrative Templates from the left pane and then System > Audit Process Creation and Enable “Include command line in process creation events”. This is important because you see the Powershell ran but now what it did.
3. Lastly we will install Elastic Agent and add the Windows Integration. This will automatically begin ingesting Security logs into the “logs-windows.security-* ” index.
<https://www.elastic.co/downloads/elastic-agent>.

Sigma Rule used in this

title: Suspicious PowerShell Activity

logsource:

category: process_creation

product: windows

detection:

selection:

Image|endswith: 'powershell.exe'

CommandLine|contains: '-Command'

condition: selection

4. Now run this command "powershell.exe -Command "Write-Host Test """.
 - a. powershell.exe - This launches the powershell engine..
 - b. -Command "Write-Host Test" - It executes the strings inside the quotes.

The detection will look something like this

Timestamp	Process	Command Line	Notes
2026-04-24 04:05:12	powershell.exe	powershell.exe -Command "Write-Host Test"	Suspicious execution

Malware Analysis

Malware analysis is the systematic process of understanding a suspicious file, URL, or code's functionality, origin, and potential impact to mitigate threats and improve security. It involves examining code without running it (static analysis) or observing its behaviour in a safe, isolated sandbox environment (dynamic analysis) to detect and neutralise malicious activity.

Tools used

- **REMnux** - it is a linux toolkit specifically curated for reverse-engineering and analyzing malware.
- **Hybrid Analysis** - It is a free online sandbox that executes the file and records its behaviour in real-time.

Analyzing File using REMnux tools (using strings and peframe)

Static Analysis using strings and peframe

I used the “**strings calc.exe > output.txt**” command to save the output of the strings command in a .txt file. The strings output reveals the file is a 64-bit Windows PE executable. Three notable strings include:

- **ShellExecuteW**: A function indicating the program launches other processes or web pages.
- **Calc.pdb**: The debug symbol path, useful for identifying the original compilation environment.
- **asInvoker**: A manifest setting ensuring the app runs without administrative privileges.

Then peframe command is as follows “**peframe calc.exe**”

```
Sections Suspicious
For each section the value of entropy is less than 6

Metadata
CompanyName      Microsoft Corporation
FileDescription   Windows Calculator
FileVersion       10.0.26100.1882 (WinBuild.160101.0800)
InternalName      CALC
LegalCopyright    © Microsoft Corporation. All rights reserved.
OriginalFilename  CALC.EXE
ProductName       Microsoft® Windows® Operating System
ProductVersion    10.0.26100.1882

Import function
SHELL32.dll       1
KERNEL32.dll      12
msvcrt.dll        15
ADVAPI32.dll      3
api-ms-win-core-synch-l1-2-0.dll 1
api-ms-win-core-processthreads-l1-1-0.dll 1
api-ms-win-core-libraryloader-l1-2-0.dll 1

Possible Breakpoint
GetCurrentProcess
GetCurrentProcessId
GetModuleHandleW
GetStartupInfoW
GetTickCount
ShellExecuteW
Sleep
TerminateProcess
UnhandledExceptionFilter

Url
http://schemas.microsoft.com/SMI/2005/WindowsSettings

File
calc.pdb          Unknown
SHELL32.dll       Library
KERNEL32.dll      Library
msvcrt.dll        Library
ADVAPI32.dll      Library
api-ms-win-core-synch-l1-2-0.dll Library
api-ms-win-core-processthreads-l1-1-0.dll Library
api-ms-win-core-libraryloader-l1-2-0.dll Library

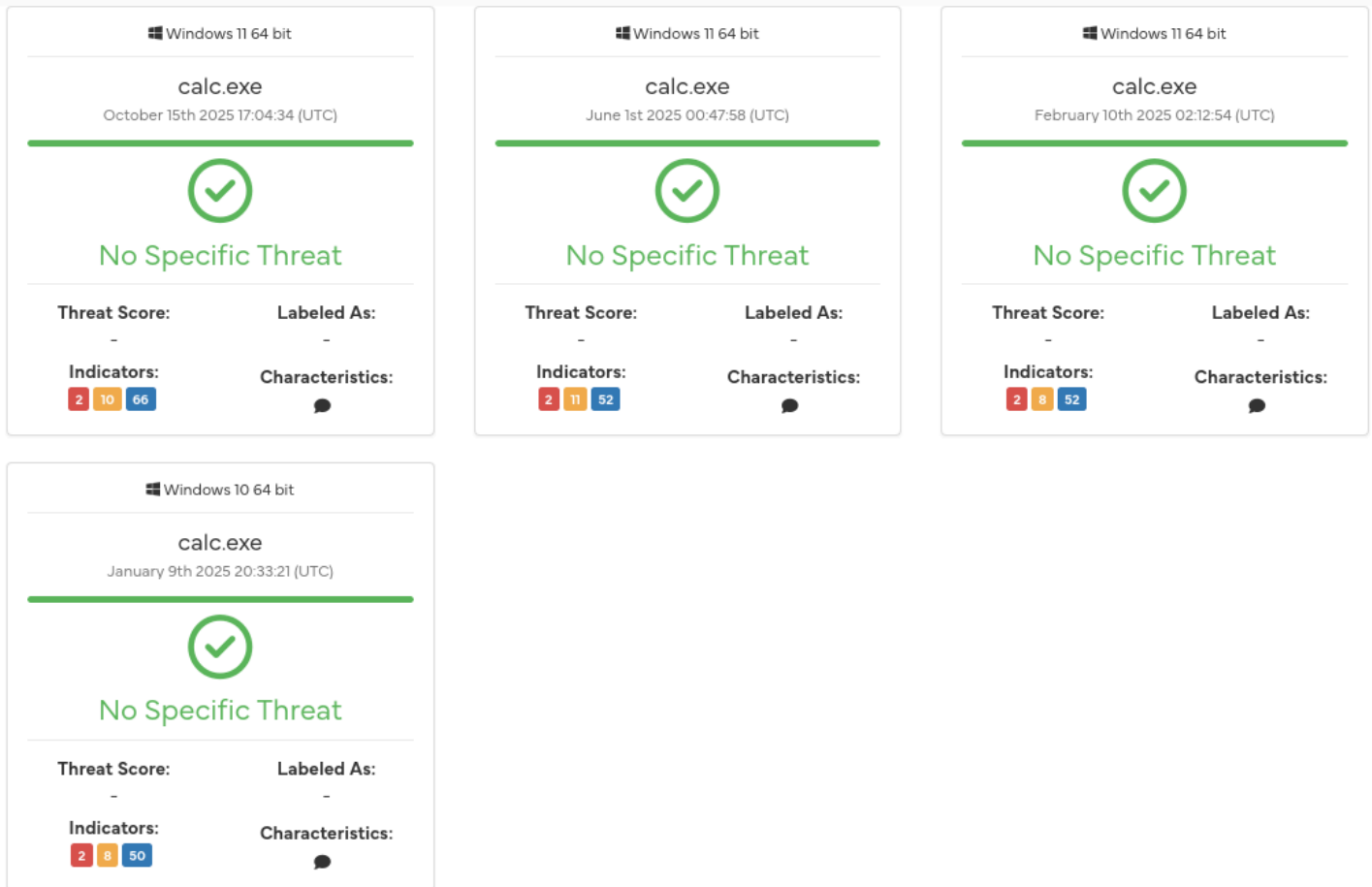
Fuzzing
Possible connections
```

Analysis of calc.exe reveals a 64-bit Windows executable mimicking the legitimate calculator. While metadata suggests Microsoft authorship, peframe flags antidis and packer features. Key suspicious behaviors include

TerminateProcess and UnhandledExceptionFilter (anti-debugging) and a Sleep function, often used to delay execution and evade sandbox detection.

Dynamic Analysis using Hybrid-Analysis

I used the calc.exe file to upload it to the hybrid analyses site.



Hybrid Analysis classifies calc.exe as “No Specific Threat” with a clean verdict from CrowdStrike and MetaDefender. Static and Machine learning analysis yielded no malicious indicators across multiple Windows versions. Despite the metadata inconsistencies noted earlier, behavioral sandboxing across different environments confirms the sample currently shows no harmful activity.

Comparing Hybrid-Analysis and REMnux tools report

While Hybrid Analysis classifies calc.exe as clean, REMnux tools reveal internal inconsistencies. Peframe identifies suspicious antidebug and packer features, alongside execution delays like Sleep. The strings output corroborates this by showing low-level imports like TerminateProcess and UnhandledExceptionFilter, common in anti-analysis routines.

Building a Vulnerability Management Pipeline

Building a vulnerability management pipeline involves creating a continuous, automated, and repeatable process for identifying, prioritizing, remediating, and verifying security vulnerabilities across an organization's IT infrastructure and software development lifecycle (SDLC).

Tools Used

OpenVAS - Open Vulnerability Assessment System is a leading open-source network security scanner that identifies vulnerabilities, misconfigurations, and outdated applications in systems.

DefectDojo - It is a leading open-source vulnerability management and Application Security Posture Management (ASPM) tool that streamlines DevSecOps by aggregating findings from over 200+ security scanners.

Steps to scan target in OpenVAS and importing report in DefectDojo

1. Open OpenVAS scanner using "gvm-start" it will open the scanner in the browser. Then go to Tasks > Wand Icon > Task Wizard.
2. Input the IP you want to scan in my case it's 192.168.204.142 and click Start Task.
3. After the task is completed click the "File Export" icon to export the file in .XML extension.
4. Go to terminal again and type command "defectdojo"

```
# defectdojo

Creating database user
Creating database
ALTER ROLE
Broken pipe
Waiting for database to be reachable
```

5. It will start like this so we have to wait for it to start.
6. Then in defectdojo create a product named "Metasploitable2 Lab".
7. Under that product create an "Interactive Engagement".
8. Lastly import the .xml file you get from the OpenVAS.

Prioritized Vulnerabilities and Mitigations.

<i>Vulnerability</i>	<i>CVSS Score</i>	<i>Description</i>
VSFTPD Backdoor	7.5	Allow Remote Unauthorized Access
SMBv1 Enables	8.1	Vulnerable to remote code execution
Weak SSL/TLS Ciphers	6.8	Susceptible to encryption attacks

Mitigation Steps of each Vulnerability

VSFTPD Backdoor:

- Update VSFTPD to latest secure version
- Remove compromised binaries and reinstall from trusted sources
- Restrict FTP access using firewall rules
- Use secure alternatives like SFTP (SSH-based)

SMBv1 Enables

- Disable SMBv1 protocol on the system

- Enable SMBv2 or SMBv3
- Apply latest OS security patches (especially for EternalBlue-type Exploits)
- Restrict SMB ports (139, 445) via firewall

Weak SSL/TLS Ciphers

- Disable weak ciphers like MD5-based suites
- Enforce strong protocols
- Configure server to use secure cipher suites only
- Regularly test using tools like SSL Labs

Incident Response Simulation

It aims to reduce the impact and disruption caused by a cyber attack should it happen. By simulating a cyber incident, the team evaluates the effectiveness of an organisation's ability to prevent, detect, contain, remediate and incident. In this task we are going to simulate a phishing attack using caldera and collect artifacts using velociraptor.

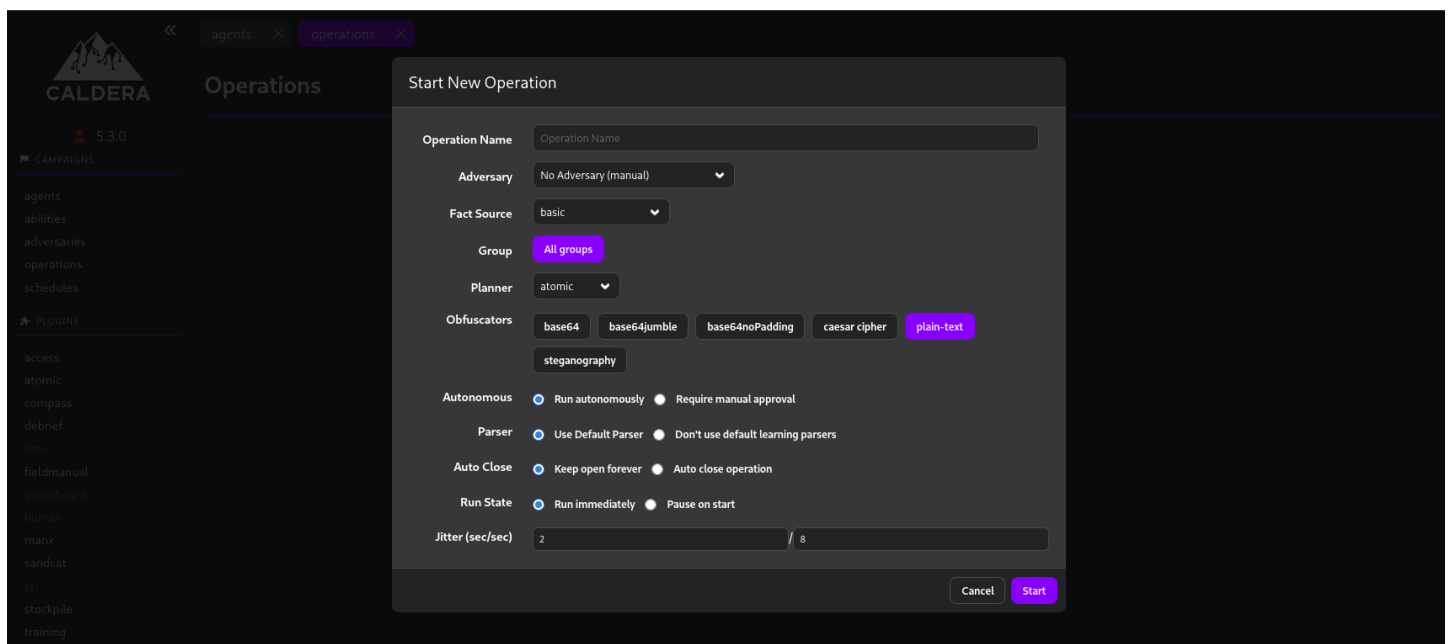
Tools used

Velociraptor - its a free and open source endpoint monitoring and incident response tool which was created by many individuals in the Digital Forensics and Incident Response community.

MITRE Caldera - it's a cybersecurity framework developed by MITRE that empowers cyber practitioners to save time, money, and energy through automated security assessments.

Configuring Velociraptor and Caldera

The attack begins with the Initial Access phase, where the Sandcat agent executes a scripted "click" on a simulated phishing attachment. Upon execution, the payload initiates a Command and Scripting Interpreter (T1059.001) technique via PowerShell. This script performs an automated File and Directory Discovery (T1083) to identify high-value documents. The path moves from a user-level process to establishing a beaconing connection back to the C2 (Command and Control) server. This demonstrates the typical progression from a single user error to an active persistent threat within the target environment.



This is the Caldera Operation Window where we have to setup



Search clients

Q

Show All





Welcome to Velociraptor!

Common tasks:

- [Inspect the server's state](#)
- [Building an Offline Collector](#)
- [Write VQL notebooks](#)
- [View Server Configuration](#)
- [Customize this welcome screen](#)

Or simply search for a client in the search bar above.

This is the dashboard of Velociraptor where we can run commands like "SELECT * FROM processes; SELECT * FROM netstat;" this to collect process and network artifacts.

Network Defense

The proactive and reactive actions taken to protect, monitor, analyse, and detect unauthorized activity, ensuring the confidentiality and integrity of computer networks and data.

Tools Used

Suricata - It's a high performance, open source network analysis and threat detection software used by most private and public organizations.

Elastic SIEM - It's an AI-driven, open-source security information and event management platform built on the Elasticsearch engine.

CrowdSec - It's an open-source and participative security solution offering crowdsourced server detection and protection against malicious IPs.

Configuring and Testing Suricata

1. To configure suricata we have to do "nano /etc/suricata/suricata.yaml" to configure the .yaml file.

```
# If copy-mode is set to ips or tap, the traffic coming to the
# interface will be copied to the copy-iface interface. If 'tap'
# copy is complete. If 'ips' is set, the packet matching a 'drop'
# will not be copied.
copy-mode: ips
#copy-iface: eth1
# For eBPF and XDP setup including bypass, filter and load balancer
# see doc/userguide/capture-hardware/ebpf-xdp.rst for more info
# Disable HW timestamp support. HW timestamps can be unreliable
# https://redmine.openinfosecfoundation.org/issues/7585
#disable-hwtimestamp: false
```

2. Setting the copy-mode to ips from ids and putting your network interface in the interface option from af-packet section.
3. Now we will create custom rules "cd /etc/suricata/rules/".
4. Then create a file "nano local.rules".
5. Next we will add the rule in it "drop ip 192.168.204.129 any -> any any (msg:"Block Malicious IP"; sid:1000001;)" " i am using my Badstore IP since i will ping it from that to check if it is working.
6. We have to mention our local.rules file to suricata.yaml, rules-files section.

```
rule-files:
- suricata.rules
- local.rules
```

7. After this restart the service "systemctl restart suricata".
8. Then try to ping using the ip you put in it. In my case it was Badstore IP and it will timeout. I try to did the nmap scan on my linux machine using Badstore.
9. Then check the /var/log/suricata/fast.log to see that it was blocked with a string saying Malicious IP.

Mapping a suricata alert to MITRE ATT&CK

When Suricata detects an event, it logs it in EVE JSON format. This format is easily ingested by Elastic SIEM. A Red Teamer maps these alerts to the ATT&CK framework to identify which stage of the kill chain was blocked.

Alert	Tactic	Technique	Notes
Port Scan Detected	Reconnaissance	T1046	Attacker scanning for ports

Risk Assessment

It's a structured process that identifies, analyzes, and prioritizes risks to an organization's digital infrastructure, including threats, vulnerabilities, and potential business impacts. It helps to enable proactive defense by evaluating asset criticality and recommending control, typically following frameworks.

Tools Used

Google Sheets - it's a free, cloud-based spreadsheet application developed by Google that allows users to create, edit, and format spreadsheets online while collaborating in real-time.

Quantitative Risk Analysis

Quantitative analysis uses hard data to determine the financial impact of a risk. We use three primary metrics:

1. **Asset Value (AV):** The total value of the data or hardware at risk.
2. **Exposure Factor (EF):** The percentage of the asset lost during a single incident.
3. **Single Loss Expectancy (SLE):** The cost of a single event (\$AV \times EF\$).
4. **Annual Rate of Occurrence (ARO):** How many times per year the event is expected to happen.
5. **Annual Loss Expectancy (ALE):** The total expected yearly cost.

Ransomware Scenario

Given are SLE and ARO,

SLE: \$10,000

ARO: 0.2

So, $ALE = SLE \times ARO$

$ALE = \$2,000$

Asset Name	SLE	ARO	ALE	Likelihood	Impact	Risk Score
Customer Database	\$10,000	0.2	\$2,000	2	4	8 (Medium)

5x5 Risk Assessment Matrix and scoring Ransomware scenario

5×5 Risk Assessment Matrix

Likelihood × Severity = Risk Rating

	1. Rare	2. Unlikely	3. Possible	4. Likely	5. Almost Certain
5. Fatal / Catastrophic	5 Acceptable Monitor	10 Reduce Risk	15 Action Required	20 Stop Activity	25 Stop Activity
4. Major Injury	4 Acceptable Monitor	8 Reduce Risk	12 Action Required	16 Stop Activity	20 Stop Activity
3. Serious Injury	3 Acceptable Monitor	6 Reduce Risk	9 Reduce Risk	12 Action Required	15 Stop Activity
2. Moderate Injury	2 Acceptable Monitor	4 Acceptable Monitor	6 Reduce Risk	8 Action Required	10 Stop Activity
1. Minor Injury	1 Acceptable Monitor	2 Acceptable Monitor	3 Reduce Risk	4 Reduce Risk	5 Action Required
	Likelihood				

Low Risk	Acceptable - Monitor	Medium Risk	Reduce Risk
High Risk	Action Required	Very High Risk	Stop Activity

According to this if we score the ransomware scenario then,

- Likelihood: 2 (Unlikely). Based on our ARO of 0.2 (once every 5 years), this falls into the "Unlikely" category.
- Impact: 4 (Major). While \$10,000 might be small for a corporation, the operational disruption of ransomware usually classifies as a "Major" impact due to the criticality of data.

Final score 4x2 = 8 (Medium Risk)

Incident Response Cycle

This cycle is a structured, four-to-six phase process used to manage cybersecurity incidents, minimizing damage, reducing recovery time, and improving future security. Consists of Preparation, Detection and Analysis (or Identification), Containment - Eradication - Recovery, and Post-Incident Activity. But in this task we will exploit a Metasploit 2 vulnerability and then use Wazuh to alert on the attack then block the attacker IP with CrowdSec and verify with a ping test.

Tools Used

Metasploit - the foundational open-source tool used for developing and executing exploit code against target systems.

Wazuh - a free open-source security platform that unifies Extended Detection and Response (XDR) and Security Information and Event Management (SIEM) capabilities.

CrowdSec - it's an open-source and participative security offering crowdsourced server detection and protection against malicious IPs.

Google Docs - it's used to document making or reports and even collaborate with others on documents.

The Incident, including Findings, Actions, and Recommendations

A security incident was identified involving the exploitation of a legacy vsftpd 2.3.4 service. The vulnerability, characterized by a built-in backdoor, allowed for unauthorized command execution and root-level shell access. The intrusion was flagged by the Wazuh XDR platform. Monitoring agents identified anomalous process spawning originating from the FTP daemon, specifically mapping to MITRE ATT&CK Technique T1190 (Exploit Public-Facing Application). Active defense measures were deployed via CrowdSec. The source IP was programmatically restricted through a distributed blocklist, effectively terminating the attacker's TCP sessions and preventing re-entry. To prevent recurrence, the primary objective is the decommissioning of the vsftpd 2.3.4 service in favor of secure alternatives such as SFTP or patched versions of ProFTPD. Additionally, network segmentation should be enforced to isolate management services, and automated remediation scripts should be integrated into the SIEM to reduce the mean time to respond for known exploits.